

# Cybersecurity Fundamentals (02270 and 02339)

**Sebastian A. Mödersheim**

Office: 321/018

Email: [samo@dtu.dk](mailto:samo@dtu.dk)

**Gaurav Choudhary**

Office: 322/214

Email: [gauch@dtu.dk](mailto:gauch@dtu.dk)

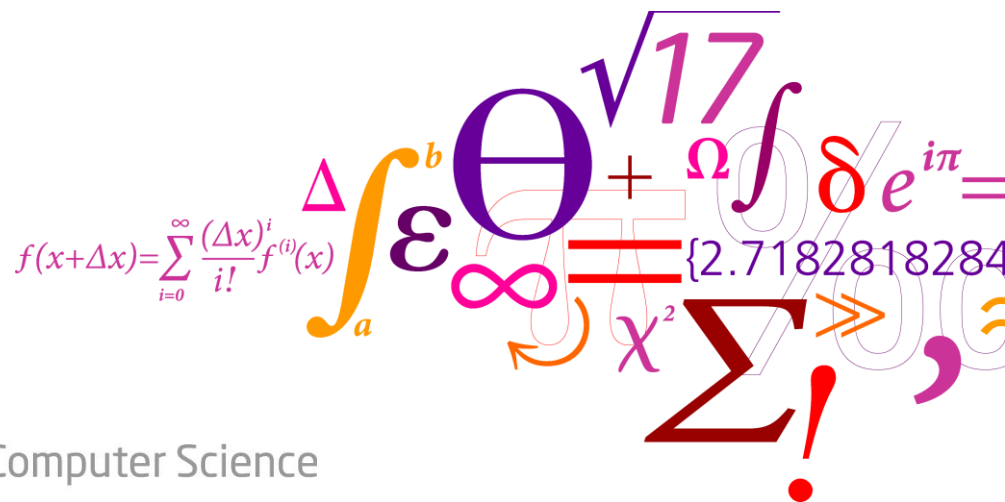
**Lejla Islami**

Office: 322/220

Email: [lejis@dtu.dk](mailto:lejis@dtu.dk)

**DTU Compute**

Department of Applied Mathematics and Computer Science



# Course Objectives

*The objective of this course is to provide a **holistic introduction** to the **basic concepts** of computer security, which will provide the necessary basis for **ongoing scholarly studies** and **starting professional activities** in the area of computer security*

- No chain is stronger than its weakest link so all aspects that impact on security must be examined
- Our intention is to cover topics broadly, but not in great detail
  - Coverage should be sufficient to allow ongoing scholarly studies in computer security (possible courses listed on the next slide)
  - Coverage should be sufficient to allow a motivated engineer to learn more about computer security form self-study and on the job learning
- A few important topics are not covered at all
  - Some will be covered in later courses for those who continue

# Course Overview

- **Lectures:** Room: LY.306.034.AUD and LY.306.035.AUD
- **Exercises:** Allocated Rooms:
  - **LY.303A.47.CR (Only allocated for 02339),**
  - LY.308.001.CR,
  - LY.308.009.CR,
  - LY.308.017.CR,
  - LY.308.101.EXP,
  - LY.308.109.EXP,
  - LY.308.117.EXP,
  - LY.308.127.CR

## Examination

- Final exam (multiple choice)

- No AID- No notes, no books etc
- 2 Hours Exam

# The Team



**Course Responsible:**  
Gaurav Choudhary

Associate Professor  
Cybersecurity Engineering  
DTU Compute

gauch@dtu.dk



**Course Responsible:**  
Sebastian A. Mödersheim

Professor  
Cybersecurity Engineering  
DTU Compute

samo@dtu.dk



**Course Responsible:**  
Lejla Islami

Assistant Professor  
Cybersecurity Engineering  
DTU Compute

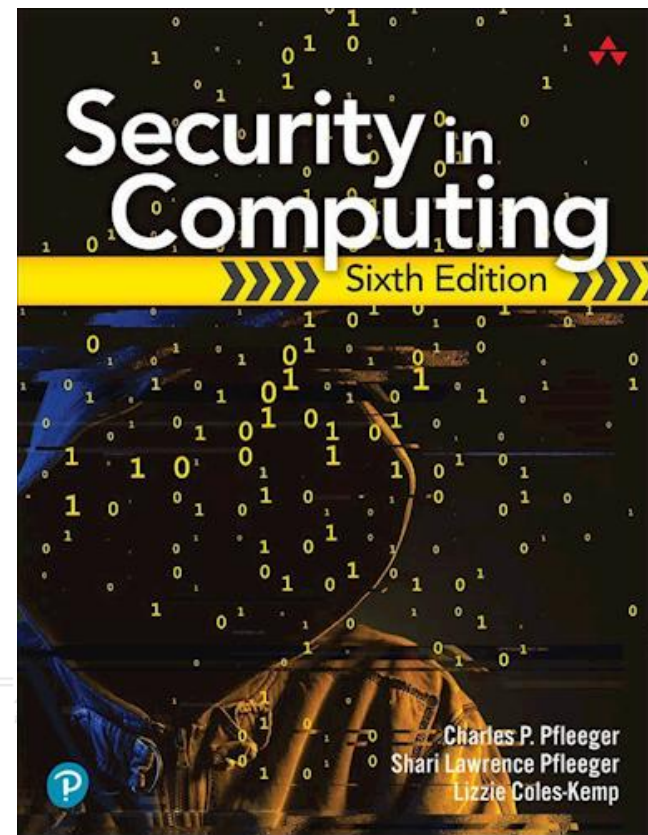
lejis@dtu.dk

# The Team: TAs

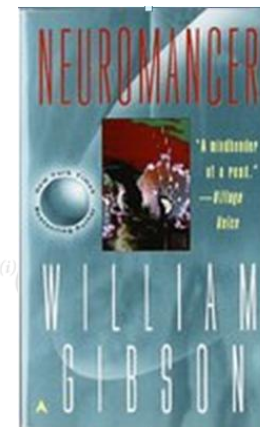
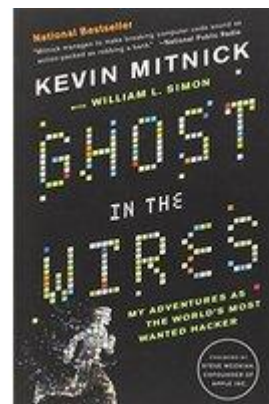
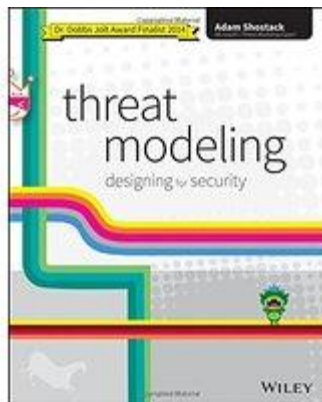
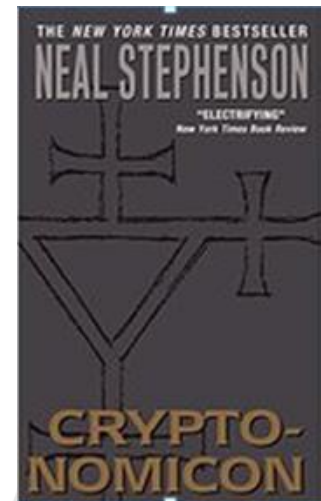
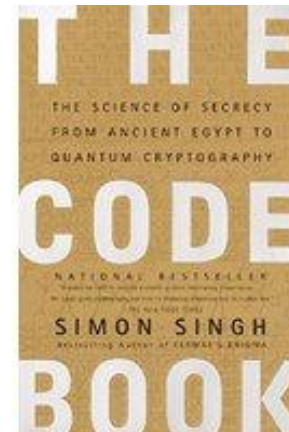
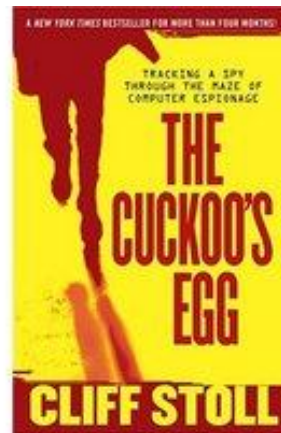
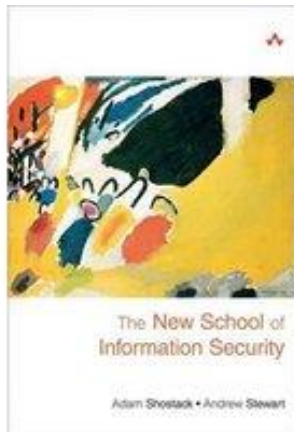
- **Tomas Silva:** s243023@student.dtu.dk
- **Amy Calleja:** s254302@student.dtu.dk
- **Arman Cheraghvandi:** s252657@student.dtu.dk
- **Pinac Chetan Joshi:** s252714@student.dtu.dk
- **Oskar Kocjančič:** s253070@student.dtu.dk
- **Mads Riber Harder:** s204473@student.dtu.dk
- **Alireza Amirinejad Daryasari:** s252610@student.dtu.dk
- **Aleksandra Martyna Blachowiak:** s250694@student.dtu.dk
- **Jakub Nowak:** s250696@student.dtu.dk
- **Luca D'Este:** lucde@dtu.dk

# Textbook

- Pfleeger & Pfleeger:  
Security in Computing  
(6th Edition)



# Extra Curricular Security Reading



# Course Schedule

| Date    | Topic                                      | Lecture By         |
|---------|--------------------------------------------|--------------------|
| 2 Sep   | Introduction                               | Gaurav & Sebastian |
| 9 Sep   | Cryptography I                             | Gaurav             |
| 16 Sep  | Cryptography II                            | Gaurav             |
| 23 Sep  | Authentication and Identity Management     | Gaurav             |
| 30 Sept | Protection/Access Control                  | Gaurav             |
| 7 Oct   | Security in Networks                       | Gaurav             |
| 14 Oct  | Autumn Holiday                             |                    |
| 21 Oct  | Security Management                        | Gaurav             |
| 28 Oct  | Protocol Security I                        | Sebastian          |
| 4 Nov   | Protocol Security II                       | Sebastian          |
| 11 Nov  | Privacy and Privacy Enhancing Technologies | Sebastian          |
| 18 Nov  | Usable Security and Privacy                | Lejla              |
| 25 Nov  | Software Security                          | Lejla              |
| 2 Dec   | Legal Issues                               | Gaurav             |

# Security courses at DTU Compute

- Two sections that focus on security at DTU Compute
  - Software Systems Engineering
    - *Focuses on modelling and analysis of information systems using language-based techniques and tools*
  - Cybersecurity Engineering
    - *Focuses on models, policies and (cryptographic) mechanisms to develop and support secure computing systems*
- Security courses at DTU Compute
  - 02231-Cryptography Fundamentals- Autumn
  - 02232-Applied Cryptography-Autumn Spring
  - 02234-Research Topics in Cybersecurity-Autumn
  - 02270-Cybersecurity Fundamentals-Autumn
  - 02271-Advanced Cybersecurity-Spring F4A
  - 02275-Ethical Hacking-Autumn
  - 02276-Usable Security and Privacy-Spring
  - 02277-Cyber Risk Management and Incident Response-Spring
  - 02278-Post-Quantum Cryptography-June
  - 02291-System Integration-Spring
  - 02244-Logic for Security-Spring
  - 02245-Program Verification-Autumn

# Cybersecurity - Specialization

- The student must follow the requirements in the general curriculum for the programme such that at least 25 ECTS points are obtained among the following courses:
  - 02231-Cryptography Fundamentals- Autumn
  - 02232-Applied Cryptography-Autumn Spring
  - 02234-Research Topics in Cybersecurity-Autumn
  - 02270-Cybersecurity Fundamentals-Autumn
  - 02271-Advanced Cybersecurity-Spring F4A
  - 02275-Ethical Hacking-Autumn
  - 02276-Usable Security and Privacy-Spring
  - 02277-Cyber Risk Management and Incident Response-Spring
  - 02278-Post-Quantum Cryptography-June
  - 02291-System Integration-Spring

# Join DTU Hacker Lab

Introducing:

## DTU Hackerlab



**What we do:**

- CTFs
- Research Talks
- Workshops
- Projects
- And more ...

**Next Events:**

|                            |             |
|----------------------------|-------------|
| - Introduction Day         | 10.09 17:00 |
| - Cyber Deception Research | 24.09 17:00 |
| - HackTheBox Event         | 03.10       |

**Octobers Topic: Home Lab**



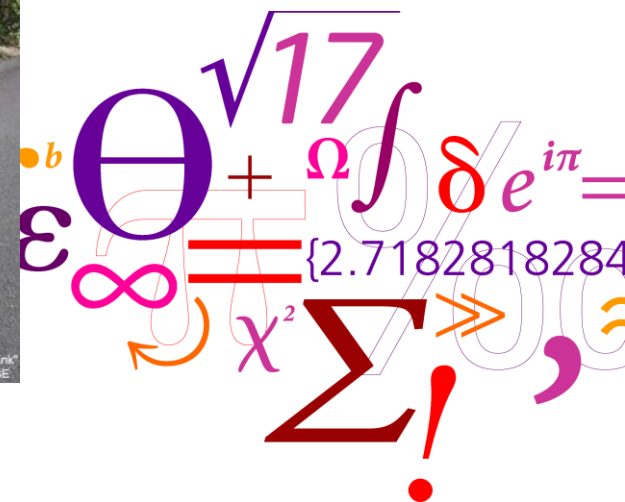
Scan for links to Discord and Info about events.  
Or visit: [hackerlab.dtu.dk](https://hackerlab.dtu.dk)

Everyone is welcome!

# An Overview of Computer Security



\*The chain is no weaker than its strongest link"  
Photo by ToHell, 2003-09-23 in Slagsta, SE



DTU Compute

Department of Applied Mathematics and Computer Science

---

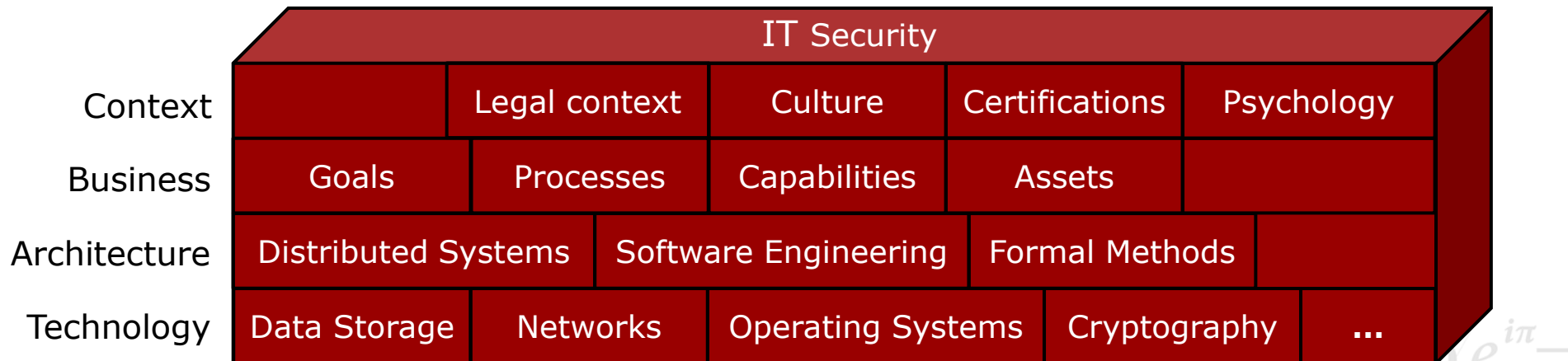
# Defining Security

- Computer security, information security, cybersecurity ...
- **NIST Computer Security Handbook:** The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability, and confidentiality of information system resources (hardware, software, firmware, information/data, telecommunications, ...)
- The security of a system, application, or protocol is always relative to
  - A set of desired properties
  - An adversary with specific capabilities
- Example: standard file access permissions in Linux and Windows are not effective against an adversary who can boot from a CD



# Elements of Cybersecurity

- Cybersecurity must consider aspects from many domains of human activity, in addition to the theory and technologies normally attributed to the domain



*... this makes it challenging, exciting and rewarding to work with!*

# The Basic Components

- Primary Security Goals (CIA-properties)
  - Confidentiality
  - Integrity
  - Availability
- Other goals frequently listed
  - Accountability
    - *Actions can be traced back to a single entity*
      - People can be made responsible for their actions
    - *Principle known as non-repudiation in cryptography*
  - Privacy (e.g. privacy families defined by *Common Criteria*)
    - *Pseudonymity, unlinkability, anonymity, unobservability*
    - *There is an inherent conflict between accountability and privacy*
  - Authenticity
    - *Requests or information are authentic and authenticated*
    - *Resources (both hardware and software) are genuine*



# Confidentiality

- Preventing unauthorised observation of information or resources (keeping secrets secret)
  - War-plans, business strategies, client confidentiality (priest/lawyers), ...
- Particularly important in military information security
  - Security models, policies and mechanisms developed to enforce the *need-to-know* principle
- Confidentiality can be ensured with cryptography
  - A cryptographic key is used to scramble (encrypt) data so that unauthorised entities cannot read it
  - Authorised entities have access to a cryptographic key so that they can restore (decrypt) data to its original form
- Access control mechanisms protect data from unauthorised access
- Confidentiality may extend to protect knowledge about the existence of information or resources

# Why Confidentiality required ???



- ✓ *It ensures that sensitive information are accessed by an authorized person and kept away from those not authorized to posses them*

# Tools for Confidentiality

- Encryption in communications
- Access control
- Authentication
- Authorization
- Physical Security



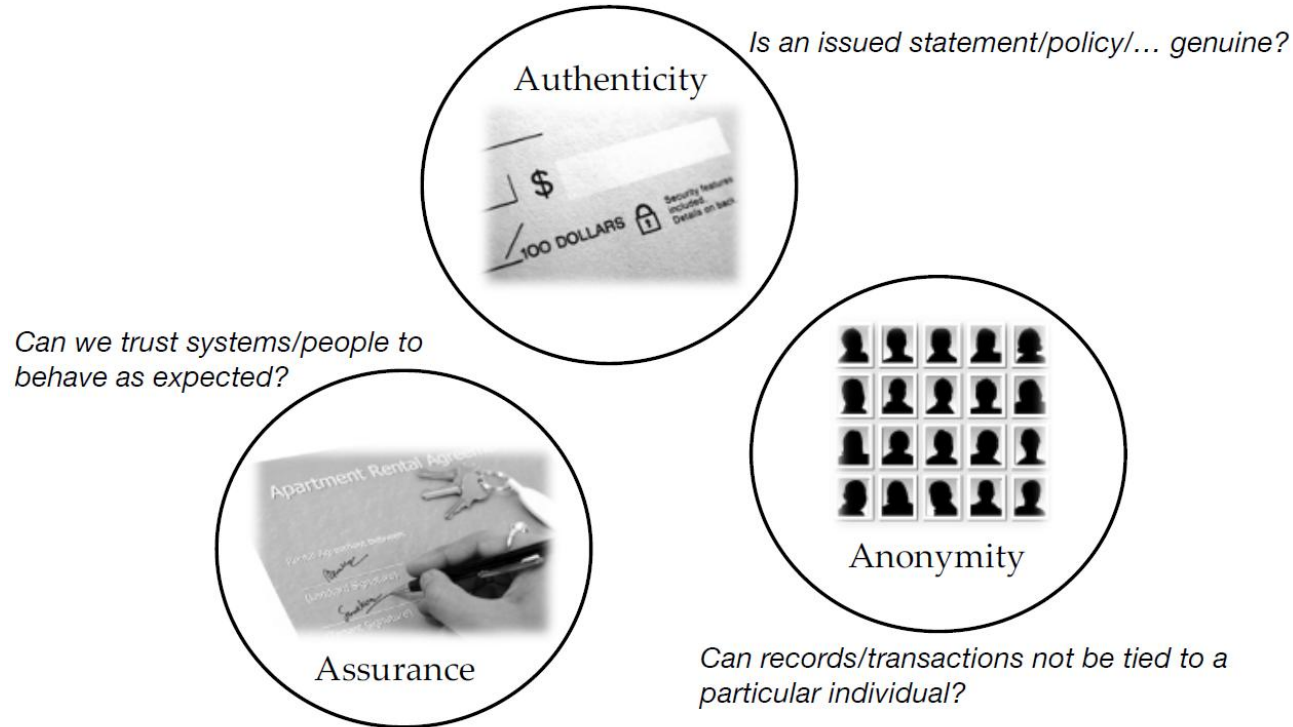
# Integrity

- Preventing unauthorised modification of information or resources
  - Data integrity pertains to the content of the information
  - Origin integrity pertains to the source of the information
    - *Origin integrity implies authentication of the source of the information, which is part of authenticity*
- Two classes of integrity mechanisms:
  - Prevention mechanisms
    - *Prevents data from being modified in unauthorised ways*  
*Prevents the bank's janitor from modifying my bank account, but does not prevent the bank manager from moving all my money to his own account*
  - Detection mechanisms
    - *Detects unauthorised modification of data after the fact*  
*Prevents neither of the scenarios above, but allows both to be detected and corrected*
- Integrity is often more important than confidentiality in commercial information systems

# Availability

- Availability means that the systems information and resources are available to authorised users when they need them
- Attacks against availability is known as *Denial-of-Service* (DoS)
  - Many spectacular DoS attacks reported in the press
- Availability is devilishly difficult and most security research has focused on confidentiality and integrity
  - It is easy to ensure confidentiality and integrity, simply unplug the computer and store it in a bank vault
- Difficulties in ensuring availability include:
  - Difficult to distinguish between high load and DoS
  - Influenced by factors outside the security model
    - *A backhoe may be used to cut power or communication supplies*

# Other Security Concepts: A.A.A.



# A.A.A.: Assurance

- ✓ Refers to how trust is provided and managed in computer systems
- ✓ Trust is difficult to quantify
- ✓ But trust, and management of trust, is essential
  - ✓ Can we trust that the OS is bug-free?
  - ✓ Can the computer trust that the user is who he claims to be?



# Tools for Assurance

- ✓ **Policies:** specify behavioral expectations that people or systems have for themselves and others
  - ✓ Example: the designers of an online music system may specify policies that describe how users can access and copy songs
- ✓ **Permissions:** describe the behaviors that are allowed by the agents that interact with a person or system
  - ✓ Example: an online music store may provide permissions for limited access and copying to people who have purchased certain songs
- ✓ **Protections:** describe mechanisms put in place to enforce permissions and policies
  - ✓ Example: the online music store would build in protections to prevent people from unauthorized access and copying of its songs



# A.A.A.: Authenticity

- The ability to determine that statements, policies, and permissions issued by persons or systems are genuine/authentic
- Can be seen as authentication + integrity
- ✓ Primary tool: **digital signatures**
  - ✓ Allow a person or system to commit to the authenticity of their documents in a unique way that achieves nonrepudiation
  - ✓ **Nonrepudiation:** property that authentic statements issued by some person or system cannot be denied
  - ✓ Bind an entity to an issued statement, or an action



# A.A.A.: Anonymity

- The property that certain records or transactions not to be attributable to any individual

- Tools:

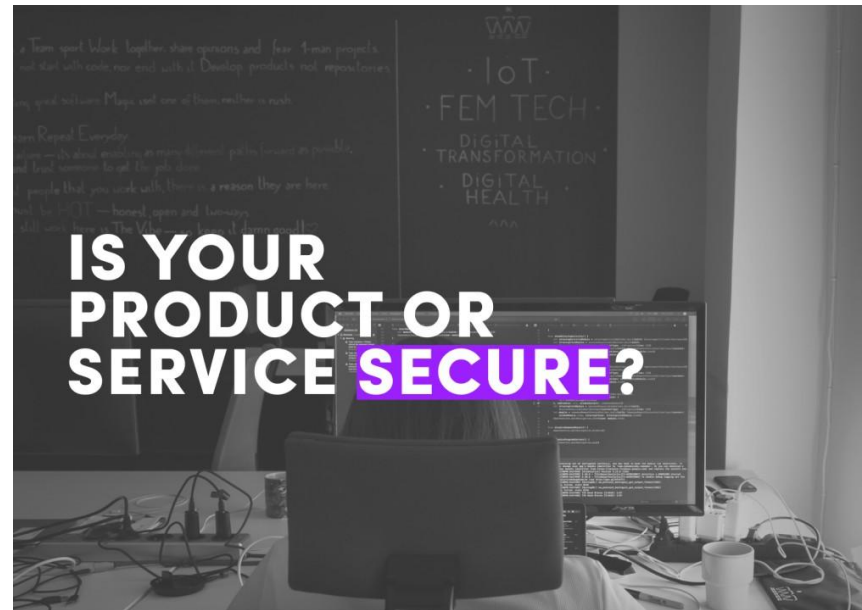


- **Proxies:** trusted agents (example: The Onion Router) that engage in actions for an individual in a way that cannot be traced back to that person
- **Pseudonyms:** fictional identities that can fill in for real identities in communications and transactions, but are otherwise known only to a trusted entity
- **Aggregation:** the combining of data from many individuals so that disclosed sums or averages cannot be tied to any individual
- **Mixing:** the intertwining of transactions, information, or communications in a way that cannot be traced to any individual



# “Is this product/system/service secure?”

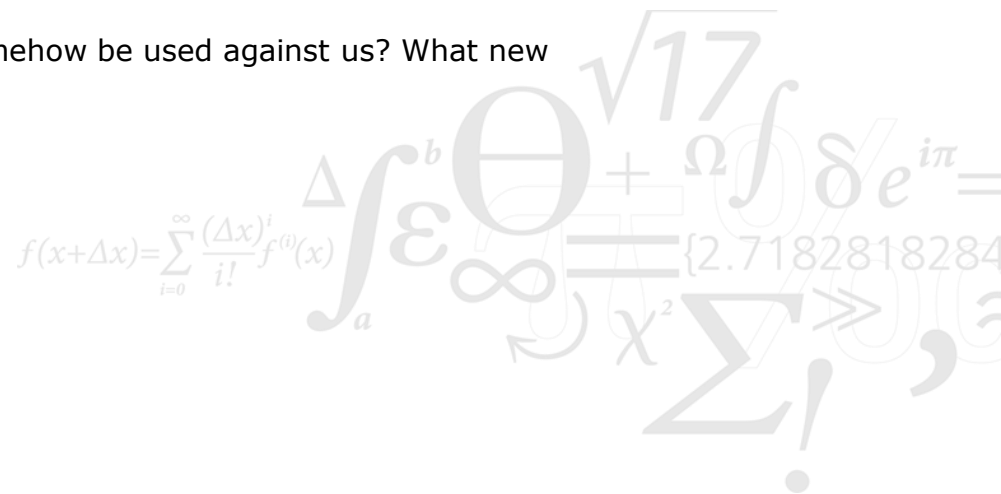
- Simple Yes/No answers are often wanted, but typically inappropriate
- Security of an item depends much on the context in which it is used
- Complex systems often include many elements and interactions with their environment/users that are open to abuse



**“No worries, our product is 100% secure. All data is encrypted with 128-bit keys, which take billions of years to break.”**

Such statements are abundant in marketing literature. Better to ask:

- What does the mechanism achieve?
- Do we need confidentiality, integrity or availability, and of what exactly?
- Who will generate the keys and how? Who will store / have access to then keys? Can we lose keys and with them data?
- Will it interfere with other security measures (backup, auditing, malware/ intrusion detection, . . . )?
- Will it introduce new vulnerabilities, or can it somehow be used against us? What new incentives might it create?
- What if it breaks or is broken?
- What are the easiest means of circumvention?
- . . .



**Q:** A smart hospital experiences the following events:

- An attacker reads patient records.
- Patient medication information is modified.
- The hospital network becomes unavailable.
- A fake message is generated pretending to come from a doctor.
- The hospital later conducts an independent audit to verify whether its security controls are working as required.
- Patients use a system where their identity cannot be linked to anonymous feedback.

Which sequence correctly identifies the security concepts?

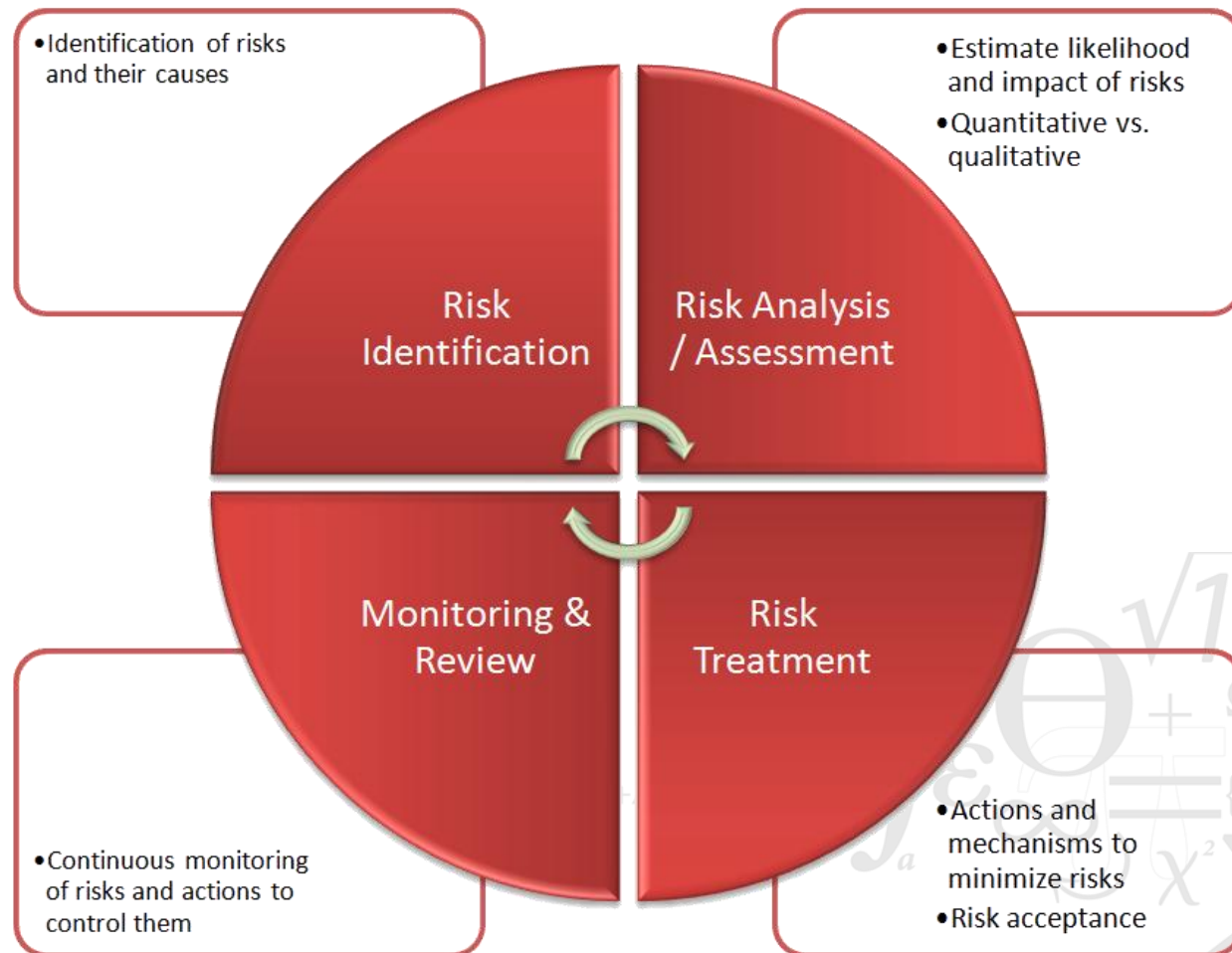
- A. Confidentiality → Integrity → Availability → Authenticity → Assurance → Anonymity
- B. Integrity → Confidentiality → Availability → Anonymity → Assurance → Authenticity
- C. Confidentiality → Availability → Integrity → Authenticity → Anonymity → Assurance
- D. Authenticity → Integrity → Confidentiality → Availability → Assurance → Anonymity

# Risks

- Security is concerned with management of risk
  - Eliminating or reducing harm to assets
- Material Harm
  - Theft of property (e.g. computers, peripherals, ...) or money
  - Harm to people or property (e.g. health, vandalism, ...)
- Immaterial Harm
  - Theft of Intellectual Property (incl. copyright violations)
  - Harm to Intellectual Property (e.g. disclosure of trade secrets)
  - Harm to reputation (e.g., website defacement, bad mouthing, ...)
- Risk Management
  - Risk Identification
  - Risk Analysis/Assessment
  - Risk Treatment
  - Monitoring/Review



# Risk Management Cycle



# Asset

- ✓ Any data, device, or other component of the environment that supports information-related activities
- ✓ Assets generally include
  - ✓ hardware (e.g. servers and switches)
  - ✓ software (e.g. mission critical applications and support systems)
  - ✓ confidential data
- ✓ Assets should be protected from illicit access, use, disclosure, alteration, destruction, and/or theft, resulting in loss to the organization



# Threats

- A threat is a potential violation of security
  - Four elements need to be present for an attack  
threat → vulnerability → opportunity → attacker (exploit)
- Four major classes of threats:
  - Disclosure (unauthorised access to information)
  - Deception (acceptance of false data)
  - Disruption (interruption or prevention of correct operation)
  - Usurpation (unauthorised control of (part of) the system)
- Five ways to deal with the effects of exploits:
  - Prevention (remove all vulnerabilities)
  - Deterrence (making exploits difficult – *but not impossible*)
  - Deflection (make other targets relatively more attractive)
  - Detection (as they happen or after the fact – *forensics*)
  - Recovery (restore the system to a usable state)

# Vulnerabilities

- Weaknesses in the Security Architecture
  - Weak assumptions
    - *Security requirements not specified or poorly understood*
  - Weak architecture
    - *Security requirements not properly identified*
    - *Security architecture does not cover all security requirements*
    - *Security Architecture not up to date (outdated requirements)*
  - Weak components
    - *Poor specification of components of the security architecture*
    - *Poor implementation of components of the security architecture*
    - *Components do not compose securely*
- Weak operation
  - Poor recruitment processes
  - Poor security awareness



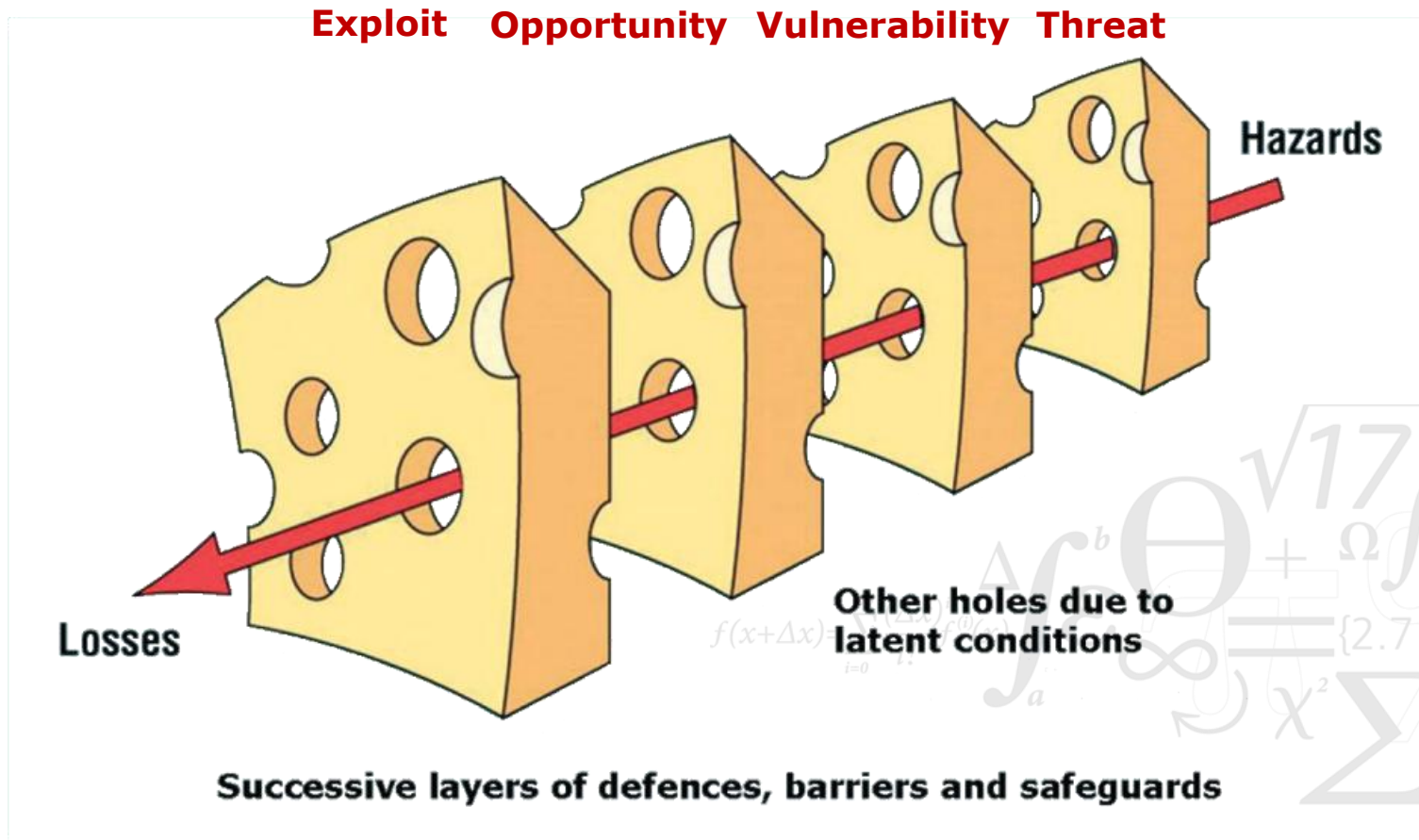
$$f(x+\Delta x) = \sum_{i=0}^{\infty} \frac{(\Delta x)^i}{i!} f^{(i)}(x)$$

$$\Delta \int_a^b \Theta + \Omega \int \delta e^{i\pi} = \{2.7182818284\}$$
$$\chi^2 \Sigma !$$

# Threats, Vulnerabilities and Attacks

## *Putting it All Together*

- The "Swiss Cheese" Model



# Pause

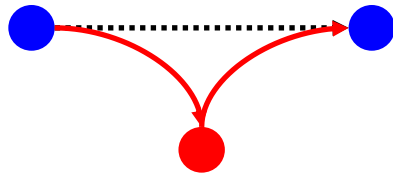


# Network Attacks

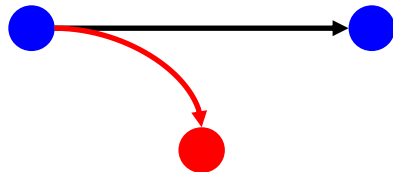
## Active attacks



*Normal communication*



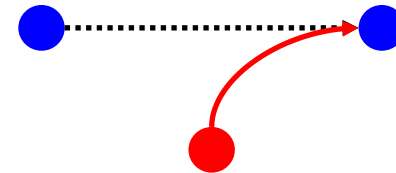
*Modification*



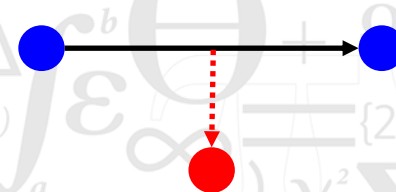
*Eaves dropping*



*Deletion*



*Fabrication*



*Traffic analysis*

## Passive attacks

**Q:** A university network administrator investigates suspicious activity on the campus network. The investigation reveals the following activities:

**Activity 1:** An attacker secretly captures network packets between students and university servers and analyses the communication patterns without changing any packets.

**Activity 2:** The attacker later sends forged packets into the network and modifies some of the ongoing communications.

**Activity 3:** The attacker continues monitoring network traffic without injecting or modifying any additional packets.

Based on these activities, which option correctly classifies them?

- A. Activity 1 – Active, Activity 2 – Passive, Activity 3 – Active
- B. Activity 1 – Passive, Activity 2 – Active, Activity 3 – Passive
- C. Activity 1 – Passive, Activity 2 – Passive, Activity 3 – Active
- D. Activity 1 – Active, Activity 2 – Active, Activity 3 – Passive

# Possible Attackers

- Insiders (>50%)
  - Disgruntled employees
  - Guests, consultants, contract workers ...
- Crackers (*hackers*)
  - Technically knowledgeable programmers
- Script-Kiddies (*cracker wannabes*)
  - Tools provided by others
- Spies (*industrial and military*)
  - Technical knowledge, technical means, many resources
- Criminals (*thieves, organized crime*)
  - Technical knowledge, technical means, many resources
- Hacktivists and Terrorists
  - Technical knowledge and means, disproportionate allocation of resources
- We need to consider: *means (method), motives and opportunity*

# Means of attackers

- Insiders
  - Knowledge of system configuration, network topologies, processes,...
  - Only computing resources provided by organisation
- Crackers (*hackers*)
  - Able to adapt tools to configuration of target
  - Able to write new tools/exploits
  - Few computing resources (apart from bot-nets)
- Script-Kiddies (*cracker wannabes*)
  - Can only use tools provided by others (already known attacks)
- Spies (*industrial and military*)
  - Technical knowledge, rich computing resources, other resources
- Criminals (*thieves, organized crime*)
  - Technical knowledge, technical means, many resources
- Terrorists
  - Probably between spies and script-kiddies, but nothing is really known

# Motivation for Attackers

- Curiosity about how the system works
  - The challenge of hacking the system
  - “Ethical hacking” (expose vulnerabilities and warn owners)
    - *SIEM cannot tell difference between white-hat and black-hat hackers, so **defenders must always react***
- Fame
  - Recognition for their achievements
- Financial Gains
  - Fraud, theft
  - Industrial Espionage
- Ideology
  - Hactivism: disrupt but do not cause serious damage
  - Cyberterrorism: disrupt/destroy important services

# Opportunities for Attacks

- Insiders
  - Daily access to the network, relatively easy to launch attacks
- Crackers
  - Difficult to access internal network
  - Have to crack the firewall first
- Script-Kiddies
  - Can only exploit holes in the firewall (and possibly wireless access)
- Spies
  - Combination of insiders and crackers
  - 3 most important means of gathering information are:
    - *Beatings, Bribery and Blackmail (3 Bs)* -- Robert Morris Sr.
- Criminals
  - Ability to infiltrate, 3Bs, otherwise difficult
- Terrorists
  - Similar to criminals

# Policy and Mechanisms

- It is always important to distinguish between the policy and the mechanism that enforces the policy
  - **Policy**: statement of what is, and what is not, allowed
  - **Mechanism**: method, tool or process for enforcing a security policy
- Security Policies may be defined in different ways
  - Different levels of detail from very general (users must not copy other users' files) to very specific (user A must not copy user B's files)
  - Different levels of accuracy from general statements in English to precise mathematical formalisms
    - *Formal statements are more precise when they are formulated correctly*
- When multiple organizations collaborate the composed entity often has a security policy based on the individual security policies
  - This raises the problem of policy composition which is inherently difficult

# Goals of Security Mechanisms

- Security mechanisms are put in place to *prevent* attacks, *detect* attacks and *recover* from attacks
- Prevention
  - Cryptography and access control are often used to prevent attacks
- Detection
  - Intrusion detection systems are often used to detect attacks during or after the attack
- Recovery
  - React to the attack
    - *Common reactions are to stop the attack in progress or allow it to continue with extensive logging (to allow the attacker to be traced)*
  - Repair the damage caused by the attack
    - *Identify the vulnerability, identify appropriate prevention mechanism (e.g., patch the system), determine damage caused by the attack, repair damage caused by the attack (e.g., roll-back of data bases to before the attack)*

# Assumptions and Trust

- Security policies are always based on some assumptions about the behaviour of components and entities in the system
- Two assumptions are generally made:
  - Security policy unambiguously partitions the system state into *secure* and *nonsecure* states
  - Security mechanism will guarantee that a system in the *secure* states will never become *nonsecure*
  - If either assumption fails the system is insecure
- A security mechanism can be characterised as:
  - Secure: it does not allow the system to enter nonsecure states
  - Precise: it allows the system to enter all secure states
  - Broad: it allow the system to enter states that are nonsecure
  - In practise, most security mechanisms are broad

# Trust Assumptions

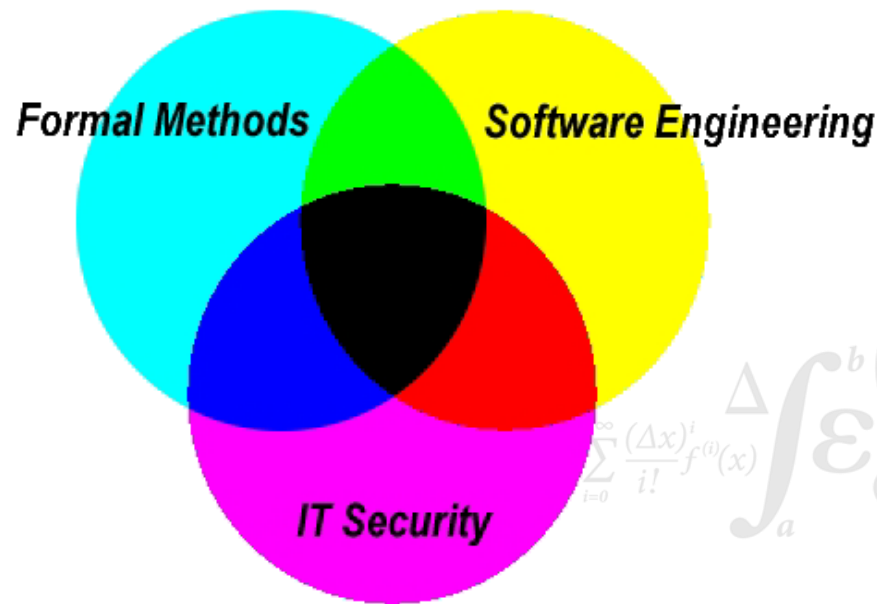
- Trusting that mechanisms work requires several assumptions
  - Each mechanism is designed to implement one or more elements of the security policy
  - The union of security mechanisms implements all aspects of the security policy
  - The mechanisms are implemented correctly
  - The mechanisms are installed and administered correctly
- So what is required to trust encrypted data from the network
  - Encryption algorithm must be strong (design)
  - Encryption algorithm must be implemented correctly (implementation)
  - Encryption software must be installed correctly (operation)
  - Cryptographic key must be secret (administration)

# Assurance

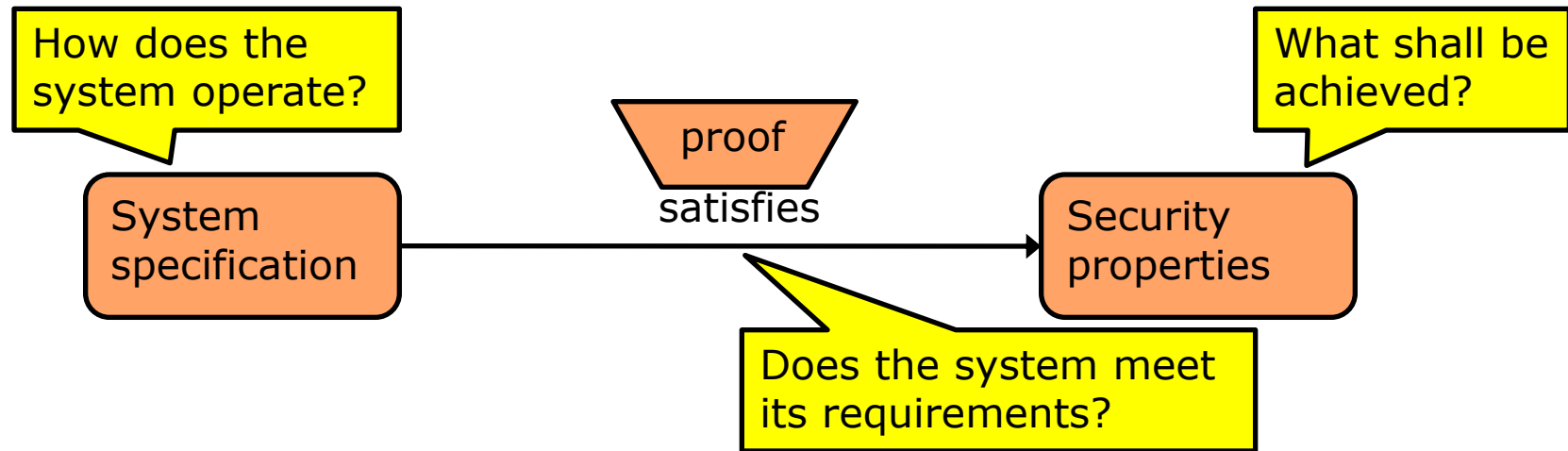
- Assurance attempts to quantify some of the assumptions about trust in the security mechanism
- Assurance requires a specification of the behaviour of the system
  - A system is said to *satisfy* a specification if the specification correctly states how the system will function
- Assurance considers all aspects of software development
  - *Specification* of the system must be correct and unambiguous
  - *Design* of the system translates the specification into components that will implement them
  - *Implementation* creates a system that satisfies the design
    - *A program is correct if its implementation performs as specified*
  - *Testing* verifies *a posteriori* if the implementation is correct
    - *NB! testing cannot prove correctness, only incorrectness*
- Stronger assurance requires formal proofs of correctness

# Formal Methods for Security

- Systems can be understood as mathematical objects.
- Formal methods based on mathematics and logic should be used to model, analyze, and construct them.
- Doing so can substantially improve the security



# Formal Methods for Security



- Even the mere attempt to formalize the security properties/goals of a system in a mathematically precise way can be revealing!
- FM group focuses on automatic methods to find either a proof or a counter example – given a specification of the system and the security properties
- Tools based on model-checking, static analysis, abstract interpretation...
- Many attacks have been detected – and fixed -- using such tools:
- H.530, Google-Apps SSO, Kerberos PKInit

# Operational Issues

- Security policies and mechanisms must be effective
  - **Defender:** the cost of an effective attack must be higher than the design, implementation and operation of the security infrastructure
  - **Attacker:** the cost of an effective attack must be lower than the benefits gained through the attack
- Risk analysis determines what attacks are plausible and determines the cost of these attacks
  - Credit card companies accept small amounts of fraud, because it is cheaper than implementing all mechanisms to ensure “perfect” security
- Cost benefit analysis establish whether the benefits of a particular countermeasure exceeds the cost of implementing and operating it
- Laws and customs in the local environment plays an important role
  - Different laws on data protection are defined in different jurisdictions
  - Policies and mechanisms that are legal, but unacceptable, in the local environment should be avoided

# Organisational Issues

- Implementing security in a large organisation is difficult and technology is often the easy bit (although we often get it wrong)
  - Benefits of security are not directly visible *on the bottom line*
  - Some security mechanisms may actually be costly
    - *Protocol overhead slows down communications*
    - *Requiring passwords to be entered frequently tends to lower productivity*
- Responsibility for computer security is not always obvious
  - IT department has responsibility for servers, hardware and software
  - Individual users are responsible for choosing good passwords (and keeping them secret)
  - If an attack exploits a weak password then who is to blame?
- Social Engineering (e.g. phishing) is surprisingly effective
- Security incidents are not always attacks
  - An employee who reads and sends private emails during work hours is generally breaching policy, but the breach is normally accepted

# Human Issues

- Social Engineering is surprisingly effective
  - Main approach used by Kevin Mitnick (FBI Most Wanted for many years)

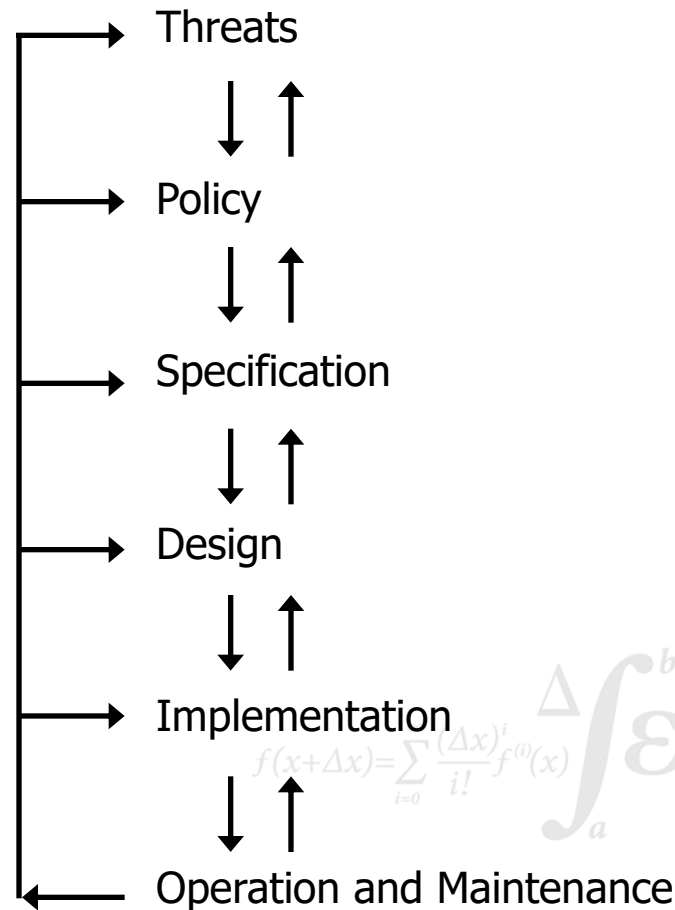


# Security Usability

- Security mechanisms must be comprehensible and acceptable



# Security Life Cycle



# Diffie-Hellman key exchange

